

4-2-1: Examining Public Key Infrastructure (PKI)

At the end of this episode, I will be able to:

1. Identify and explain the importance of public key infrastructure, given a scenario.

Learner Objective: *Identify and explain the importance of public key infrastructure, given a scenario.*

Description: In this episode, the learner will examine public key infrastructure. We will explore the common components such as certificate authorities, public keys, Certificate Signing Requests, Certificate Revocation Lists and more.

- What is Public Key Infrastructure or PKI?
 - A framework for securing communications through the issuing and lifecycle management of digital keys and certificates
 - Implemented to facilitate encryption, authentication, and digital signatures in online transactions and communications.
- What are some of the components of PKI?
 - Certificate authority or CA
 - Root/offline CA
 - The highest-level authority in the certificate hierarchy, responsible for issuing and signing certificates to subordinate CAs
 - This CA's security is especially crucial and is commonly taken offline to prevent a compromise
 - Subordinate/Issuing CA
 - An intermediate authority that operates under a root CA issuing and signing digital certificates * *
These intermediate CAs are sometimes referred to as issuing CAs. In these instances, they will issue all certificates lower than the root CA in the PKI hierarchy.
 - Standalone CA vs. Enterprise CA
 - Standalone - is an independent CA that issues and manages certificates, doesn't rely on a hierarchical structure, and is typically used in smaller or isolated environments.
 - Enterprise CA - that is integrated into an organization's network and issues and manages certificates for internal use.
 - Internal CA vs. External CA
 - Internal - a CA used within an organization's internal network to issue certificates, with the authority not trusted outside the organization.
 - External - a CA used for issuing certificates to entities publically, with the authority being trusted globally.
 - Root of trust - a trusted entity or authority whose digital signature and public key are accepted as a foundation of trust in the PKI hierarchy.
 - Digital certificate
 - An electronic document issued by a trusted authority, or Certificate Authority (CA), that binds a public key to an individual, device, or service
 - These documents serve as a means of authentication and encryption for secure communications, digital signatures, and access control.
 - Additional components
 - Certificate Signing Request (CSR)
 - A formal request generated by an entity, such as an organization or user, to request a digital certificate from a CA.
 - A CSR can be sent to an internal or external CA
 - Certificate Revocation List (CRL)
 - A dynamically updated list maintained by a CA containing serial numbers of certificates that have been revoked or are invalid before expiry
 - This provides verification and trustworthiness of the certificate.
 - This is an older resource-intensive method for determining whether a certificate is valid or revoked.
 - Online Certificate Status Protocol (OCSP)
 - A real-time network protocol used to check the validity and revocation status of certificates

- This provides verification and trustworthiness of the certificate
 - An alternative method for determining whether a certificate is valid or revoked.
 - Online responder
 - A server that processes OCSP requests (certificate validity check requests)
 - This provides quick, real-time responses on the validity and revocation status of certificates.
 - Less resource intensive, great efficiency
 - Key escrow
 - The process of storing a copy of cryptographic keys with a trusted third-party
 - This is commonly done for recovery or backup purposes in case the original key is lost or compromised.
-

- Additional Resources:

- If applicable